

CyberSight

Business-Aware Vulnerability & Cyber Risk Prioritization Platform for E-Commerce Organizations

Preliminary Project Concept

Problem Statement & Project Scope

Version 0.1 | Graduation Project Draft

Core idea: prioritize vulnerabilities using technical severity, exploit likelihood, and business impact — not technical severity alone.

PROJECT CONCEPT

1. Concept Overview

CyberSight is a web-based cybersecurity decision-support platform designed for e-commerce organizations. Its purpose is to help security and IT teams prioritize known vulnerabilities by combining three complementary perspectives: **technical severity, likelihood of exploitation, and business impact**. The platform is not intended to replace vulnerability scanners, SIEM platforms, or incident-response tools. Instead, it adds organizational context to existing vulnerability intelligence so that teams can decide what should be addressed first.

TECHNICAL
CVE / CVSS

EXPLOITABILITY
EPSS / known exploitation

BUSINESS
Asset criticality / impact

2. Problem Statement

E-commerce organizations depend on interconnected digital assets such as web applications, customer databases, payment-related services, administrative portals, order-management systems, and supporting infrastructure. These assets may contain multiple known vulnerabilities at the same time. Security teams therefore face a practical prioritization problem: deciding which vulnerabilities require immediate attention when time, staffing, and remediation capacity are limited.

A purely technical view of vulnerability severity is not always sufficient for this decision. A vulnerability with a high technical severity score may exist on a low-criticality system, while another vulnerability with a lower technical score may affect a business-critical asset that supports online sales, customer data, order processing, or service availability. Treating both cases only by technical severity can lead to remediation priorities that do not fully reflect the organization's operational and business exposure.

The problem is therefore not simply the existence of vulnerability data, but the difficulty of translating technical vulnerability information into business-aware priorities. E-commerce organizations need a structured way to combine technical severity and exploit likelihood with the criticality and business impact of affected assets, then present the result in a form that supports consistent and explainable remediation decisions.

CyberSight addresses this problem by providing a decision-support layer that integrates public vulnerability intelligence with an organization-specific e-commerce asset model. The platform will calculate and visualize prioritized cyber risk, helping users understand not only how severe a vulnerability is technically, but also why it matters to the business and where remediation effort should be directed first.

Problem in one sentence: security teams may know which vulnerabilities are technically severe, but still lack a clear, business-aware method for deciding which vulnerabilities should be remediated first.

PROJECT BOUNDARIES

3. Project Scope

Scope definition. The graduation-project implementation of CyberSight will focus on vulnerability and cyber-risk prioritization for a controlled e-commerce organizational case study. The platform architecture may be extensible to other sectors in the future, but the design, data model, business-impact assumptions, demonstrations, and evaluation in this project will be centered on e-commerce organizations.

3.1 In Scope

- **E-commerce asset inventory:** Create and manage a limited set of representative assets such as the e-commerce web application, customer database, order-management system, administrative portal, inventory system, and supporting servers.
- **Public vulnerability intelligence:** Import or retrieve selected CVE records and associated technical attributes such as CVSS severity and affected-product information from trusted public sources.
- **Exploit-likelihood enrichment:** Optionally enrich CVE records with EPSS scores and/or a known-exploitation indicator when available, so prioritization is not based on CVSS alone.
- **Business criticality assessment:** Assign each asset a structured business-criticality profile based on dimensions such as operational dependency, customer impact, data sensitivity, financial impact, and service availability.
- **Business-aware risk prioritization:** Combine the technical vulnerability information with asset criticality to generate an explainable priority or risk score and rank vulnerabilities for remediation.
- **Risk treatment tracking:** Allow users to record a basic treatment decision or remediation status such as patch, mitigate, monitor, accept, or resolved.
- **Residual-risk view:** Provide a simplified before/after representation of risk when a treatment or security control is applied, without attempting to model every control in a full enterprise GRC framework.
- **Analytical dashboard:** Visualize high-priority vulnerabilities, risk distribution by asset, severity, exploitation likelihood, business criticality, and treatment status.
- **Basic user roles:** Support a small set of roles such as Security Analyst and Security/IT Manager with role-appropriate access to assessment and reporting functions.

3.2 Out of Scope

- Automatic vulnerability scanning of real networks or endpoints.
- Penetration testing, exploitation, or offensive security functionality.
- Real-time network monitoring, intrusion detection, or SIEM replacement.
- Automated incident response or security orchestration (SOAR).
- Malware analysis or threat-hunting functionality.
- Direct integration with production systems of a real organization during the graduation-project phase.
- Full compliance auditing against every cybersecurity regulation or control framework.
- Prediction of future cyberattacks using a custom machine-learning model as a core dependency.

3.3 Data Scope and Availability

The project will deliberately use a hybrid data strategy so that the technical evidence is real while the organizational context remains safe, controllable, and feasible for a student project:

Data layer	Planned source	Role in CyberSight
Vulnerability records	NIST National Vulnerability Database (NVD)	CVE details, CVSS severity, affected-product information and other vulnerability attributes.
Exploit likelihood	FIRST EPSS	A probability-oriented exploitation score that can enrich prioritization.
Saudi context	Saudi National Cybersecurity Authority (NCA)	E-commerce cybersecurity guidance and national risk-management context; may also be used to validate local relevance.
Organizational context	Controlled synthetic e-commerce case study	Asset inventory, business processes, asset criticality and business-impact ratings created using a documented scoring rubric.

Important design principle: the synthetic component will not invent vulnerability facts. It will represent the organization-specific context that is normally private or unavailable, while CVE/CVSS/EPSS data will come from public real-world sources.

3.4 Minimum Viable Product (MVP)

The MVP should remain intentionally small enough to be completed, tested, and demonstrated reliably. A successful first version will implement this end-to-end flow:

Define e-commerce assets	Import selected CVEs	Enrich with CVSS / EPSS	Assign business criticality	Calculate priority	Rank & visualize risks	Record treatment / residual risk
--------------------------	----------------------	-------------------------	-----------------------------	--------------------	------------------------	----------------------------------

3.5 Scope Boundaries for Feasibility

- The project will use a deliberately limited number of representative e-commerce assets rather than attempting to model a full enterprise environment.
- The vulnerability dataset will be a selected and relevant subset rather than a complete mirror of all global CVE records.

- The prioritization logic must be transparent and explainable; the core system will not depend on a black-box AI model.
- Advanced enrichment such as EPSS, local NCA relevance, or residual-risk comparisons can be implemented after the core MVP is stable.
- The project will be evaluated primarily as a decision-support information system: correctness of data handling, consistency of prioritization, usability, explainability, and usefulness for risk-triage decisions.

Final preliminary scope statement

CyberSight will be developed and evaluated as a web-based, business-aware vulnerability and cyber-risk prioritization platform for an e-commerce case study. It will combine real public vulnerability intelligence with structured organizational context to rank remediation priorities, visualize risk, and support basic treatment decisions. It will not perform vulnerability discovery, live monitoring, penetration testing, or automated incident response.

4. Preliminary Reference Basis

The initial concept and scope are aligned with publicly available cybersecurity resources that can support later implementation and justification:

- NIST National Vulnerability Database (NVD) — public vulnerability intelligence and CVSS-related data.
- FIRST Exploit Prediction Scoring System (EPSS) — public exploit-likelihood data for CVEs.
- Saudi National Cybersecurity Authority (NCA) — Cybersecurity Guidelines for e-Commerce.
- Saudi National Cybersecurity Authority (NCA) — National Framework for Cybersecurity Risk Management (NFCRM).

Status: Preliminary draft for team discussion and supervisor feedback. The scoring formula, exact asset list, dataset size, and evaluation metrics should be finalized after the project idea is formally approved.